



New Age Access Management Portal — Complete Submission Document

Candidate: Soujanya Das Roy

Repository: <https://github.com/SoujanyaDasRoy/NewAgeDemoTask>

Deployment Link: <https://new-age-demo.vercel.app>

Automated Tests: 48 / 48 Passing (100% Pass Rate)



Executive Summary & Submission Checklist

DELIVERABLE	REQUIREMENT	STATUS	LINKS / REFERENCES
Part 1	Working Deployed Application Link	✓ Complete	https://new-age-demo.vercel.app
Part 2	GitHub Repository with Docs & Setup	✓ Complete	GitHub Repo
Part 3	Core Workflow & State Persistence	✓ Complete	48/48 End-to-End Tests Passing
Improvements	1–2 High Impact Improvements Report	✓ Complete	Slack Webhooks + Time-Bound Auto-Expiry
AI Usage	Tools, Prompts, Edits & Judgment	✓ Complete	Documented below
Loom Video	5–10 Min Walkthrough Link	✓ Complete	Walkthrough Link

Demo Personas & Credentials

PERSONA	ROLE	DEPARTMENT	EMAIL	PASSWORD	PRIMARY DEMO FLOW
Priya Sharma	EMPLOYEE	Product Team	priya.sharma@newage.com	password123	Self & on-behalf access requests, team approvals
Soujanya Das Roy	ADMIN	IT Support	soujanyadasroy@gmail.com	password123	Request approval, IT manual fulfillment, SCIM config, Access IDs
Arjun Mehta	EMPLOYEE	Engineering	arjun.mehta@newage.com	password123	Engineering board owner, cross-team approvals

High-Impact Improvements Report

Improvement 1: Real-Time 2-Way Interactive Slack Webhook & Decision Engine

1. What was identified

In standard enterprise access systems, approvers (managers, department leads) face severe notification fatigue. Being forced to context-switch, open a browser, sign into a portal, and navigate an approval queue creates friction. As a result, access tickets languish for hours or days.

2. Why it matters

Slack is where modern teams already work. Bringing the full approval decision lifecycle directly into Slack reduces Mean Time to Approve (MTTA) from **hours to under 30 seconds**.

3. What was changed

- **Interactive Block-Kit Messaging:** Every submitted request dynamically formats into an enterprise Block-Kit payload containing 8 metadata fields (Request ID, Requester with Department, Beneficiary, Policy Routing, Assigned Approver, Fulfillment Mode, Access Duration, and SOC-2 Access ID), business justification blockquote, and direct action buttons: `[✓ Approve Access]` and `[× Reject]`.
- **HMAC-SHA256 Cryptographic Verification:** Added `verifySlackSignature()` using constant-time `crypto.timingSafeEqual` with a 5-minute replay-window check to protect against replay and spoofing attacks.
- **Atomic Two-Way Synchronization:** Approving or rejecting in Slack executes an atomic ACID transaction in Neon PostgreSQL, updates the audit log, and replaces the Slack message with a live confirmation card (`✅ Approved by @user at 3:45 PM`).

- **Portal Deep-Linking:** Added `[Review in Portal ↗]` linking directly to `https://new-age-demo.vercel.app/?approval=NAR-XXXX`.

4. What was intentionally NOT done and why

- **We intentionally did not mandate a multi-tenant Slack App Directory OAuth install:** Enterprise Slack App installs require global Slack Workspace Admin privileges, which introduces major enterprise friction. Instead, we architected this with standard incoming webhooks + interactive endpoints so any team can plug in their webhook in under 60 seconds.

Improvement 2: Time-Bound Access Auto-Expiry & 1-Click Extension Engine (SOC-2/ISO-27001)

1. What was identified

In the base prototype, access permissions were indefinite and permanent by default. In enterprise identity governance, standing privileges are a primary cause of audit failures and insider credential breaches (privilege creep).

2. Why it matters

SOC-2 Trust Services Criteria (CC6.1, CC6.3) and ISO-27001 require time-bound access controls and periodic access certification.

3. What was changed

- **Duration Presets & Expiration Calculation:** Added structured duration pickers (`30 Days` , `90 Days` , `6 Months` , `Permanent`) with automatic target expiration calculation (`requiredUntil`).
- **Automated Expiry Worker:** Created `autoExpireRequests()` that continuously evaluates active permissions and transitions expired access to `EXPIRED` status with timeline annotations.
- **In-App 14-Day Extension Flow:** Requesters can click `+ Request 14-Day Extension` before access expires, generating an auditable renewal request for manager sign-off.

4. What was intentionally NOT done and why

- **We intentionally did not hard-delete expired rows from the database:** Deleting records destroys the compliance trail. Instead, permissions transition to `EXPIRED` status, the user's active session rights are revoked, and the audit log maintains an immutable permanent record.



AI Usage, Taste & Human Judgment

1. AI Tools Used

- **Antigravity (Advanced Agentic Assistant / Gemini 2.5 Pro):** Backend architecture, subagent orchestration, database transaction modeling, and automated test suite construction.
- **Claude 3.5 Sonnet:** Complex Block-Kit layout formatting and Next.js 16 App Router optimizations.

2. Key Prompts & Directives

- *"Eliminate all AI slop: no floating raw zeros, no mismatched pastel cards, no scary warning triangles on standard cross-team requests."*

- "Implement true neutral Linear / Apple obsidian dark mode (`#0C0D0E` , `#141518` , `#EDEDED`) instead of 90s bluish/navy slate."
- "Wrap all database mutations in Prisma ACID transactions so audit logs, notifications, and request status updates succeed or fail atomically together."
- "Enforce strict duplicate signup prevention and single-line button typography with `white-space: nowrap`."

3. Human Judgment & Manual Edits

- **Rejected AI "Exception" Terminology:** The raw AI generation produced confusing jargon like "Cross-Department Exception Warning". I manually intervened to rephrase this into human-friendly enterprise language: "  Cross-Department Resource · Managed by Marketing Team".
- **Removed Alarming Warning Aesthetics:** AI models default to placing yellow/amber alert boxes and warning triangles on any conditional logic. I overrode this to use calm neutral cards with `Building2` and `Users` icons.
- **Fixed Button Wrapping:** When Windows high-DPI scaling caused `Request Access` text to wrap onto two lines, I refactored the design system tokens with `white-space: nowrap` and uniform padding.
- **Engineered Test Session Abstraction:** Discovered that Next.js server actions throw when executed in standalone CLI scripts because `cookies()` lacks an HTTP context. Created `lib/test-session.ts` to allow 48/48 automated tests to verify the live database.